

# OPERATION SILVER CHAIN

Lab-05 — Red Team Ops Roadmap

|                |                                           |
|----------------|-------------------------------------------|
| Clasificacion: | Confidencial — Uso educativo              |
| Adversario:    | APT28 (Fancy Bear) — GRU                  |
| Fecha:         | 30/05/2026                                |
| Duracion:      | ~20 horas                                 |
| Entorno:       | atackcorp.local — DC-01 / WKSTN-01 / Kali |
| Operador:      | Adrian Camacho                            |
| Estado:        | COMPLETADO — 6/6 fases                    |

## Resumen ejecutivo

SILVER CHAIN simula un ataque APT28 (Fancy Bear) partiendo de una cuenta de helpdesk sin privilegios elevados. Mediante abuso de ACLs de Active Directory, delegacion Kerberos avanzada y forja de tickets, se logra compromiso total del dominio atackcorp.local — incluyendo acceso a DC-01 con bypass de PAC Validation via Diamond Ticket.

# 1. Entorno y Credencial Inicial

---

## Infraestructura

| Host     | IP        | OS                  | Rol                                        |
|----------|-----------|---------------------|--------------------------------------------|
| DC-01    | 10.0.2.10 | Windows Server 2022 | Domain Controller + ADCS + SQL Server 2022 |
| WKSTN-01 | 10.0.2.8  | Windows 11          | Workstation objetivo                       |
| Kali     | 10.0.2.9  | Kali Linux 2026.1   | Atacante / C2                              |

## Credencial inicial

| Usuario       | Contrasena    | Privilegio        | Vector de entrada           |
|---------------|---------------|-------------------|-----------------------------|
| helpdesk.ruiz | Helpdesk2024! | Helpdesk (sin DA) | GenericWrite sobre WKSTN-01 |

## 2. Kill Chain Ejecutada

---

### FASE 01 — Reconnaissance

MITRE: T1087.002

SharpHound v2.5.9 ejecutado desde WKSTN-01 como helpdesk.ruiz. 354 objetos recolectados e importados en BloodHound CE. Confirmados dos attack paths: helpdesk.ruiz -> GenericWrite -> WKSTN-01 y fin.garcia -> GenericWrite -> iis\_svc.

**Resultado:** 354 objetos BloodHound — attack paths confirmados

### FASE 02 — RBCD Abuse

MITRE: T1558.001 / T1136.002

Creacion de cuenta de maquina ATTACKER\$ via MachineAccountQuota=10. Escritura de msDS-AllowedToActOnBehalfOfOtherIdentity en WKSTN-01. S4U2Self + S4U2Proxy -> TGS como Administrador@WKSTN-01. Acceso a C\$ de WKSTN-01 via impacket-smbclient con ticket Kerberos.

**Resultado:** C\$ WKSTN-01 accesible como Administrador sin credenciales en claro

### FASE 03 — Shadow Credentials

MITRE: T1556 / T1649

pywhisker anade KeyCredential al atributo msDS-KeyCredentialLink de iis\_svc usando la cuenta fin.garcia. certipy-ad autentica via PKINIT con el certificado generado, obteniendo TGT y hash NTLM de iis\_svc.

**Resultado:** iis\_svc NTLM: b329981877f0ca1243192863f356a2f9

### FASE 04 — Silver Ticket

MITRE: T1558.002

Domain SID obtenido via ldapsearch. Silver Ticket forjado con impacket-ticketer usando el hash NTLM de iis\_svc para el SPN MSSQLSvc/DC-01.atackcorp.local:1433. Acceso a SQL Server con SYSTEM\_USER = ATACKCORP\Administrador. Ticket valido sin contactar al KDC.

**Resultado:** Acceso MSSQLSvc/DC-01:1433 — sin KDC — SELECT SYSTEM\_USER = Administrador

### FASE 05 — Diamond Ticket

MITRE: T1558.001

krbtgt AES256 obtenido via DCSync. Rubeus diamond genera TGT real con PAC modificado usando la clave AES256 del krbtgt. Ticket convertido de kirbi a ccache con impacket-ticketConverter. Acceso a C\$ de DC-01 confirmado — bypass PAC Validation demostrado.

**Resultado:** C\$ DC-01 accesible — TGT real + PAC modificado — bypass PAC Validation

### FASE 06 — C2 + Cleanup

MITRE: T1071.001 / T1070

Beacon Sliver LIGHT\_CARTLOAD establecido en WKSTN-01 como ATACKCORP\Administrador.  
Cleanup OPSEC: ATTACKER\$ eliminado del dominio, msDS-KeyCredentialLink de iis\_svc limpiado,  
artefactos eliminados de WKSTN-01 y DC-01, beacon eliminado de Sliver.

|                   |                                               |
|-------------------|-----------------------------------------------|
| <b>Resultado:</b> | Beacon LIGHT_CARTLOAD activo — OPSEC completo |
|-------------------|-----------------------------------------------|

### 3. Crown Jewels Obtenidos

| # | Objetivo                   | Tecnica                   | Resultado                                         |
|---|----------------------------|---------------------------|---------------------------------------------------|
| 1 | Acceso C\$ WKSTN-01        | RBCD S4U2Proxy            | TGS Kerberos sin credenciales en claro            |
| 2 | Hash NTLM iis_svc          | Shadow Credentials PKINIT | b329981877f0ca1243192863f356a2f9                  |
| 3 | Acceso MSSQLSvc/DC-01:1433 | Silver Ticket (sin KDC)   | Forjado localmente — SYSTEM_USER = Administrador  |
| 4 | Acceso C\$ DC-01           | Diamond Ticket            | TGT real + PAC modificado — bypass PAC Validation |
| 5 | Beacon WKSTN-01            | Sliver HTTP               | LIGHT_CARTLOAD — ATACKCORP\Administrador          |

## 4. Mapeo MITRE ATT&CK;

| Tactica              | Tecnica                | ID        | Herramienta                |
|----------------------|------------------------|-----------|----------------------------|
| Discovery            | Account Discovery      | T1087.002 | BloodHound CE + SharpHound |
| Persistence          | Create Machine Account | T1136.002 | impacket-addcomputer       |
| Privilege Escalation | RBCD S4U2Proxy         | T1558.001 | impacket-getST             |
| Privilege Escalation | Diamond Ticket         | T1558.001 | Rubeus                     |
| Credential Access    | Silver Ticket          | T1558.002 | impacket-ticketer          |
| Credential Access    | Shadow Credentials     | T1556     | pywhisker                  |
| Credential Access    | PKINIT                 | T1649     | certipy-ad                 |
| Lateral Movement     | Pass-the-Ticket        | T1550.003 | impacket-smbclient         |
| Command & Control    | HTTP Beacon            | T1071.001 | Sliver                     |
| Defense Evasion      | Indicator Removal      | T1070     | impacket + pywhisker       |

## 5. Lecciones Aprendidas

---

### L-01 pywhisker rompe impacket del sistema

pywhisker instala impacket==0.12.0 que tiene bug con Python 3.13. Reinstalar impacket==0.13.1 tras usar pywhisker: `pip install impacket==0.13.1 --break-system-packages`

### L-02 Evil-WinRM + Kerberos requiere configuracion

Requiere FQDN resoluble en `/etc/hosts` y realm configurado en `/etc/krb5.conf`. impacket-smbclient es mas fiable que Evil-WinRM para autenticacion Kerberos.

### L-03 Diamond Ticket requiere AES256 del krbtgt

El hash NTLM no es suficiente para Rubeus diamond. Obtener AES256 via DCSync antes de intentar el Diamond Ticket.

### L-04 kirbi->ccache para usar tickets desde Linux

Rubeus genera formato .kirbi (Windows). impacket requiere .ccache. Convertir con: `impacket-ticketConverter diamond.kirbi diamond.ccache`

### L-05 SQL Server no pre-instalado en DC-01

Descargar en Kali y subir via Evil-WinRM upload. El archivo es grande (~266MB) — planificar tiempo de transferencia.

### L-06 SharpHound placeholder en el arsenal

Verificar binarios del arsenal antes de empezar con: `file SharpHound.exe`. Descargar binario real desde GitHub si es necesario.

## 6. Cleanup OPSEC

| Artefacto                                 | Host      | Estado    |
|-------------------------------------------|-----------|-----------|
| ATTACKER\$ (cuenta maquina RBCD)          | DC-01 AD  | Eliminado |
| msDS-KeyCredentialLink de iis_svc         | DC-01 AD  | Limpiado  |
| beacon_lab05.exe                          | WKSTN-01  | Eliminado |
| SharpHound.exe + ZIP collection           | WKSTN-01  | Eliminado |
| Rubeus.exe + diamond.kirbi                | DC-01     | Eliminado |
| SQLServerExpress.exe + SQLEXPRESS_x64.exe | DC-01     | Eliminado |
| Beacon LIGHT_CARTLOAD                     | Sliver C2 | Eliminado |